Análise de arquivo suspeito

Share

codigo.py
73 lines

PY

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Revisando recomendações de resposta e contenção

Resposta curta: é malware. Mais precisamente, é um *backdoor* do tipo *reverse shell*, que dá acesso remoto não autorizado à máquina. A análise abaixo fica no nível de triagem.

1. **Identificação.** É um script Python sem comentários, documentação ou licença (só uma docstring vazia). A classe principal se chama `Backdoor` e a instância, `my_backdoor`, então o próprio código declara a finalidade.
2. **Comportamento de rede.** Ao ser executado, ele abre sozinho uma conexão de saída para um endereço fixo no código (192.168.43.38, porta 4444) e passa a esperar instruções. É a assinatura do reverse shell: a máquina comprometida é quem chama o controlador. Por isso o monitoramento de conexões de saída é o que costuma detectar esse tipo de coisa. O IP é privado (faixa típica de hotspot de celular Android) e a porta 4444 é o padrão de listeners do Metasploit. Isso sugere ambiente de laboratório, não uma campanha pela internet.
3. **Capacidades.** O script roda em loop obedecendo ao operador remoto. Ele executa comandos arbitrários do sistema e devolve a saída, troca de diretório, envia arquivos da máquina ao operador (exfiltração), grava arquivos recebidos do operador (introdução de outras ferramentas) e se encerra sob comando. Mapeando para o MITRE ATT&CK: T1059 (execução de comandos), T1041 (exfiltração pelo canal de C2), T1105 (transferência de ferramentas), T1095 (protocolo fora da camada de aplicação) e T1571 (porta não padrão).
4. **Ausência de controles legítimos.** Não há interface, aviso, consentimento, autenticação do operador nem criptografia. Tudo roda silenciosamente com os privilégios de quem executou. Não há persistência nem ofuscação, então é rudimentar, e o código parece ter falhas que podem impedir que funcione como está. Isso não muda a classificação, porque o que conta é a função projetada.
5. **Existe uso benigno?** Não como programa. Ferramentas legítimas de administração remota (SSH, RDP) exigem autenticação, usam criptografia e dependem do consentimento do dono da máquina. O mais provável é que seja material didático de segurança ofensiva, já que lembra bastante exemplos de cursos da área. Mesmo assim, é uma ferramenta de uso dual cuja função é a de um backdoor.

Veredito: malicioso, um Backdoor/RAT (reverse shell) em Python, com confiança alta. Em laboratório, é um exercício. Numa máquina real onde ninguém o instalou conscientemente, é um comprometimento.

Se isso apareceu num computador que não é de laboratório:

- Não execute o arquivo. Se precisar estudá-lo, use apenas uma VM isolada e sem rede.
- Desconecte a máquina da rede e encerre o processo Python.
- Procure conexões de saída para 192.168.43.38:4444.
- Revise arquivos criados ou lidos recentemente, já que o backdoor permite enviar e baixar arquivos.
- Troque as senhas acessíveis a partir daquela conta e investigue como o arquivo chegou ali.
- Para buscas e regras YARA, use o IP e a porta acima e as strings `[-]Error during command Execution` e `[+] Upload Succesful`.

Mantive a análise no nível de triagem e defesa. Não vou ajudar a corrigir, aprimorar ou implantar esse código.

Qual é a categoria principal deste malware?

Confirmando o tipo de acesso remoto do malware ▸

Backdoor (acesso remoto), no subtipo reverse shell. Na prática, é um RAT (*Remote Access Trojan*) bem rudimentar.

O critério é a função central do código, que é abrir e manter um canal para o operador controlar a máquina à distância. As demais capacidades (enviar e baixar arquivos, mudar de diretório) são apoio a esse controle remoto, e não o objetivo do programa.

Por isso ele não se encaixa nas outras categorias:

- **Ransomware:** não cifra nem bloqueia arquivos.
- **Infostealer:** não coleta credenciais ou dados por conta própria. O operador precisa pedir cada arquivo.
- **Worm/vírus:** não se replica nem se espalha.
- **Dropper/downloader:** o upload de arquivos existe, mas é secundário.

"Backdoor" descreve a função, e "trojan" descreve a forma de entrega, quando o programa se disfarça de algo legítimo. Este arquivo não traz nenhum disfarce, então a classificação por comportamento é Backdoor. Se ele fosse distribuído embutido em outro software, aí sim seria um Trojan com função de backdoor.

Os antivírus costumam rotular esse tipo de amostra com nomes do tipo `Backdoor.Python.*` ou `Trojan.Python.Backdoor`, mas o nome exato varia conforme o fornecedor.